



DAS Policy

Security Planning

No:
2100-23

Effective:
March 5, 2024

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

This policy defines the requirements for developing an effective ***Security Plan***, including the selection of security controls and enhancements for Ohio Department of Administrative Services (DAS)-Managed information systems.

The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, “Security and Privacy Controls for Federal Information Systems and Organizations,” family identifiers and control numbers are provided in parentheses next to requirement headers, where applicable. The requirements of the NIST SP 800-53 Planning (PL) control family are addressed in this policy.

II. Scope

The scope of this policy includes all DAS-managed information systems and the DAS ***System*** and ***Service Owners*** who maintain them.

III. Policy

DAS is issuing this policy to protect DAS-managed information systems. DAS system and Service Owners shall ensure that security planning documents are developed and maintained for all DAS-managed information systems.

- A. **System Security Plan (PL-2)**: All system Security Plans shall align with the requirements outlined in DAS Standard DAS-ITS-2100-23-A, “System Security Plan Standard.

- B. **Rules of Behavior (PL-4)**: Ohio Administrative Policy IT-04, “Use of Internet, E-mail and Other IT Resources,” as well as DAS Policy 700-01, “Information Technology Resource Usage,” outline the rules of behavior for individuals who access the state’s information systems. These rules describe user responsibilities and expected behavior with regard to information and information system usage.
- C. **Information Security Architecture (PL-8)**: An information security architecture shall be developed, describing the overall philosophy, requirements and approach to protecting the **Confidentiality, Integrity** and **Availability** of system information. The information security architecture shall be integrated into and support the enterprise architecture. Information security assumptions about, and dependencies on, external services shall be included in the information security architecture.
1. The information security architecture shall be updated when significant changes occur, or at least annually, to reflect updates in the enterprise architecture.
 2. Information security architecture changes shall be reflected in the Security Plan and any applicable procurement/acquisitions policies or contractual terms and conditions.
 3. The information security architecture shall reflect a defense-in-depth approach, which requires layers of security controls.
 - a) The security controls shall operate in a coordinated and mutually reinforcing manner.
 - b) Layered security controls shall be obtained from different suppliers, to further expand the defense-in-depth approach.
- D. **Compliance**: Security planning requirements for DAS-managed information systems shall be reviewed any time there is a contract renewal, significant changes to a **DAS-Managed System Asset** or following a significant security incident.

A significant change is defined as a substantial modification that alters the mission, configuration or basic vulnerabilities of the DAS-Managed System Asset. Changes that may indicate the need for a new risk assessment and an updated Security Plan include new or significantly changed:

1. Business Requirements
2. Hardware
3. Application Programs
4. External Users
5. Telecommunications

6. Location of the IT System (e.g., a new physical environment or a new organization)
7. IT System Interfaces

IV. Definitions

- A. Availability. Ensuring timely and reliable access to and use of information.¹
- B. Confidentiality. Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.²
- C. DAS-Managed System Asset. Information, hardware, software and services required to support state business, and identified during the risk assessment process as assets that need to be protected. Primary responsibility for managing these system assets may be assigned to DAS OIT personnel or other outside entities.
- D. Integrity. Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.³
- E. Security Plan. Formal document that provides an overview of the security requirements for an information system or an information security program and describes the security controls in place or planned for meeting those requirements.⁴
- F. Service Owner. A Service Owner is responsible for the delivery (design, performance, integration), continual improvement and management of assigned IT services.
- G. System Owner. Person responsible for the development, procurement, integration, modification, operation, and maintenance, and/or final disposition of an information system.⁵

V. Authority

ORC 125.18

¹ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

² *Ibid.*

³ *Ibid.*

⁴ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁵ Boyens, Jon, Celia Paulsen, Rama Moorthy, Nadya Bartol, “NIST SP 800-161, Supply Chain Risk Management Practices for Federal Information Systems and Organizations, April, 2015, <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-161.pdf>>.

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-04, Use of Internet, E-mail and Other IT Resources	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 700-01 Information Technology Resource Usage	https://das.ohio.gov/technology-and-strategy/policies
DAS-ITS-2100-23-A, System Security Plan Standard	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
01/19/2021	New policy for DAS.
08/02/2021	Conducted routine maintenance review of citations and references.

Date	Description of Change
03/05/2024	Updated the policy template. Added a revision history review frequency statement.